

Classification: Internal

# AETHERIA INFRASTRUCTURE RESEARCH (AIR)

## ISMS Scope Statement

AIR-ISMS-SCO-001 | Version 1.0 | May 2026

### Document Control

|                   |                                                                                                                         |
|-------------------|-------------------------------------------------------------------------------------------------------------------------|
| Document ID       | AIR-ISMS-SCO-001                                                                                                        |
| Version           | 1.0                                                                                                                     |
| Status            | Approved                                                                                                                |
| Classification    | Internal                                                                                                                |
| Document Owner    | Head of Security & Compliance                                                                                           |
| Approved By       | Chief Executive Officer                                                                                                 |
| Approval Date     | May 2026                                                                                                                |
| Review Cycle      | Annual / following any significant organisational or technology change                                                  |
| Next Review Due   | May 2027                                                                                                                |
| Standard Clause   | ISO/IEC 27001:2022 — Clause 4.3: Determining the Scope of the ISMS                                                      |
| Related Documents | AIR-ISMS-ORG-001 Organisation Profile   AIR-ISMS-AST-001 Asset Inventory   AIR-ISMS-POL-001 Information Security Policy |

### 1. Purpose

This document defines the boundaries and applicability of AIR's Information Security Management System (ISMS). It establishes what is included within the ISMS, what is excluded and why, and how the ISMS interfaces with parties and systems outside its boundary.

A clearly defined scope is a mandatory requirement of ISO/IEC 27001:2022 Clause 4.3 and forms the foundation on which all ISMS controls, risk assessments, and audits are based. An auditor, new team member, or partner reviewing this document should be able to determine precisely which systems, people, locations, and activities fall under AIR's ISMS.

### 2. Context Inputs

ISO/IEC 27001:2022 Clause 4.3 requires that the scope is determined by considering the internal and external issues from Clause 4.1, and the requirements of interested parties from Clause 4.2. Both are documented in full in the AIR Organisation Profile (AIR-ISMS-ORG-001). The key inputs that directly shaped the scope decision are summarised below.

| Input                                                            | Source                                                       | How It Shaped the Scope                                                                                                                |
|------------------------------------------------------------------|--------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Government research data classified Restricted                   | Latvian federal agency Data Sharing Agreement   ORG-001 §8.1 | The existence of Restricted government data mandates that all systems capable of storing or processing that data must be within scope. |
| GDPR obligations for employee and research subject personal data | GDPR Articles 5, 30, 32   ORG-001 §8.1                       | Personal data is processed across M365, SharePoint, and HR systems. All systems touching personal data must be in scope.               |

**Classification: Internal**

|                                                           |                                        |                                                                                                                                                                                                            |
|-----------------------------------------------------------|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AI model weights classified Restricted                    | AIR-ISMS-AST-001 PA-003   ORG-001 §3.2 | ARIA model weights represent core commercial IP. GitHub Enterprise and Azure ML must be in scope.                                                                                                          |
| 25 contractors with rotating access                       | ORG-001 §2.4   RSK-005                 | Contractor access creates a persistent offboarding risk. All contractor accounts and their access paths are in scope.                                                                                      |
| Three office locations across two countries               | ORG-001 §2.3                           | Physical security controls at all three locations must be in scope to avoid creating an unmonitored attack surface at any site.                                                                            |
| ISO/IEC 27001:2022 certification as a strategic objective | ORG-001 §7.2                           | Certification requires the scope to be defined, documented, and auditable. The scope must be neither so narrow as to exclude material risks, nor so broad as to be unmanageable for the current team size. |

### 3. Formal Scope Statement

---

The following is AIR's formal ISMS scope statement. This exact wording is used in all audit and certification documentation.

The ISMS of Aetheria Infrastructure Research S.L. (AIR) covers the management of information security across all activities, systems, personnel, and physical locations involved in the delivery of AIR's government-affiliated research programmes, ARIA AI platform operations, and advisory services. The scope encompasses AIR's headquarters in Madrid, Spain; its offices in Brussels, Belgium and Riga, Latvia; all cloud infrastructure operated under the Microsoft Azure air-prod tenant and Microsoft 365 tenancy; the GitHub Enterprise organisation airtech; all Intune-enrolled endpoint devices; on-premises research data repositories at the Madrid HQ; and all permanent employees, contractors, and research collaborators who access AIR systems or information assets. The ISMS is implemented in accordance with ISO/IEC 27001:2022.

This scope statement is available as documented information per ISO/IEC 27001:2022 Clause 4.3. It is reviewed annually and following any significant change to AIR's organisational structure, technology environment, or business activities.

### 4. Scope Inclusions

---

The following sections define in detail what is included within the ISMS boundary.

#### 4.1 Physical Locations

| Location               | Address                                    | Role                                                                                                        | Physical Assets in Scope                                                                                                                                                            |
|------------------------|--------------------------------------------|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Madrid HQ</b>       | Calle de Alcalá 189<br>28009 Madrid, Spain | Primary headquarters. Executive leadership, Infrastructure Analytics, IT Operations, Security & Compliance. | Server room (on-premises repositories). All workstations and managed endpoints. Network infrastructure. Physical access control systems. CCTV. UPS and physical security perimeter. |
| <b>Brussels Office</b> | Avenue Louise 54<br>1050 Brussels, Belgium | EU policy, Legal & Partnerships, government relations.                                                      | All workstations and managed endpoints. Network infrastructure. Physical access control (building security). No on-premises servers or data repositories.                           |

**Classification: Internal**

|                                 |                                                            |                                                                          |                                                                                                                                                           |
|---------------------------------|------------------------------------------------------------|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Riga Office</b>              | Skolas iela 45,<br>29249 Riga,<br>Latvia                   | AI Engineering hub. Model development and research software.             | All workstations and managed endpoints. Network infrastructure. Physical access control (building security). No on-premises servers or data repositories. |
| <b>Remote Working Locations</b> | Approved home and remote locations across EU member states | Hybrid working by AIR employees and contractors from approved locations. | Intune-managed endpoint devices only. Home/remote network infrastructure is excluded from scope (see Section 5 — Exclusions).                             |

## 4.2 Organisational Units and Personnel

All six AIR departments and all personnel within them are in scope, regardless of location or working arrangement:

| Personnel Category                     | In-Scope Population                                                                                        | Access Provisioning                                                                                                |
|----------------------------------------|------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| Permanent Employees                    | All 120 permanent staff across Madrid, Brussels, and Riga, including those on leave or working remotely.   | Full Entra ID accounts. Standard and elevated access per role. Onboarded via HR-triggered IT provisioning process. |
| Contractors and Research Collaborators | All 25 active contractors and research collaborators with access to any AIR system or information asset.   | Scoped Entra ID accounts. Access limited to systems required for the engagement. Offboarded on contract end date.  |
| Temporary Staff                        | Any temporary staff engaged for more than five consecutive working days who require access to AIR systems. | Treated as contractors for ISMS purposes. Full onboarding and offboarding process applies.                         |

Personnel are in scope regardless of their physical location when working. A Madrid-based employee working from home is in scope. Their home network is not.

## 4.3 Systems and Technology

| System                                                       | Scope Rationale                                                                                                                     | Asset ID               |
|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| Microsoft Azure — air-prod tenant                            | Primary cloud environment hosting all production research data, AI model workloads, and storage. Contains Restricted assets.        | SA-001, SA-002, SA-003 |
| Microsoft Entra ID                                           | Identity and access management plane for all AIR systems. Compromise of Entra ID would affect the entire ISMS.                      | SA-004                 |
| Microsoft 365 (Exchange Online, Teams, SharePoint, OneDrive) | Primary communication and collaboration platform. Contains Internal and Confidential information.                                   | SA-005, SA-006         |
| GitHub Enterprise (org: airtech)                             | Hosts Restricted AI model source code and research pipelines. Core IP asset requiring full ISMS coverage.                           | SA-007                 |
| On-premises research repositories — Madrid HQ                | Legacy Restricted research datasets not yet migrated to Azure. Physical and logical controls both in scope.                         | SA-008                 |
| Microsoft Intune                                             | Endpoint management platform. Controls the security posture of all 145 managed devices.                                             | SA-009                 |
| Jira (Atlassian Cloud)                                       | Project management tool. Contains Internal and Confidential project data and is used for ISMS action tracking.                      | SA-010                 |
| Confluence (Atlassian Cloud)                                 | Internal knowledge base. Contains Internal and Confidential documentation including ISMS policies and research programme notes.     | SA-011                 |
| Azure Key Vault                                              | Secrets management for all application credentials, API keys, and certificates. Compromise would affect multiple dependent systems. | SA-012                 |

**Classification: Internal**

|                                                |                                                                                                                           |                |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|----------------|
| Intune-managed Windows endpoints (145 devices) | All corporate laptops and workstations issued to employees and contractors. Primary user access point to all AIR systems. | PA-010, PA-011 |
|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|----------------|

#### 4.4 Information Assets

All information assets documented in AIR-ISMS-AST-001 (Information Asset Inventory) are within the ISMS scope. The following classification-level summary applies:

| Classification      | In-Scope Asset Examples                                                                                                                                                                    | Control Level                                                                                                  |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| <b>Restricted</b>   | Government-affiliated research data (PA-001), critical infrastructure analysis datasets (PA-002), AI model weights (PA-003), security configurations (PA-006), incident evidence (PA-005). | Highest controls. Strict need-to-know. Encrypted at rest and in transit. Access logged and reviewed quarterly. |
| <b>Confidential</b> | Partner contracts and research agreements (PA-007), HR records (PA-008), financial records (PA-009).                                                                                       | Strong controls. Role-based access. Sensitivity labels enforced in M365.                                       |
| <b>Internal</b>     | Working research documents (PA-010), internal project data (PA-011), AI source code (PA-004).                                                                                              | Standard controls. Available to all authorised staff. Not for external distribution.                           |
| <b>Public</b>       | Approved publications, press releases, conference papers.                                                                                                                                  | No access restriction. Standard integrity controls only.                                                       |

#### 4.5 Business Activities and Services

The following business activities are within the ISMS scope:

- Delivery of government-commissioned infrastructure research programmes, including all data collection, analysis, modelling, and reporting activities
- Operation and maintenance of the ARIA AI platform, including model training, deployment, inference, and API delivery to licensed operators
- Advisory and consultancy engagements where client data is processed or AIR systems are used to support delivery
- All internal operational activities (IT operations, HR, legal, finance, procurement) to the extent they involve AIR information assets
- Information security management activities: risk assessment, internal audit, policy development, incident response

### 5. Scope Exclusions

ISO/IEC 27001:2022 Clause 4.3 requires that any exclusions from the scope are justified and that they do not affect AIR's ability to meet its information security obligations or the requirements of interested parties. The following items are explicitly excluded from the ISMS scope, with documented justification for each.

Excluded items that interact with in-scope systems must have documented interfaces and controls to protect the boundary. See Section 6 — Interfaces.

| Exclusion                      | Justification                                                                                                                                                                                        |  | Boundary Control                                                                                                                         |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Personal / BYOD Devices</b> | Personal devices are not owned or managed by AIR and cannot be brought into compliance with AIR's endpoint security policy. AIR does not have the legal right to apply MDM profiles or monitoring to |  | Conditional Access policy enforces a device compliance check before granting access to Restricted or Confidential systems. Non-compliant |

### Classification: Internal

|                                                     |                                                                                                                                                                                                                                                                       |  |                                                                                                                                                                                                                                               |
|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                     | personal devices.                                                                                                                                                                                                                                                     |  | devices are blocked. Contractors requiring Restricted access must use an AIR-managed device or Azure Virtual Desktop.                                                                                                                         |
| <b>Home and Remote Networks</b>                     | AIR does not own, operate, or have administrative control over home broadband, hotel Wi-Fi, or other networks used by remote workers. Imposing ISMS controls on these networks is not technically or legally feasible.                                                |  | All remote access to in-scope systems is via Entra ID authentication with MFA enforced. VPN is required for access to on-premises Madrid HQ systems. The managed endpoint is in scope, the network it connects from is not.                   |
| <b>Client-Operated Systems and Portals</b>          | Government and infrastructure operator systems accessed by AIR staff (e.g. government data portals, secure submission platforms) are operated by the client and governed by the client's own security policies. AIR has no administrative control over these systems. |  | AIR staff accessing client systems must do so from in-scope managed endpoints only. Data retrieved from client systems and stored on AIR infrastructure immediately falls within ISMS scope.                                                  |
| <b>Field Research Locations Not Operated by AIR</b> | Field data collection at infrastructure sites (e.g. substations, transport nodes, water facilities) is conducted by AIR researchers using managed devices. The physical sites themselves are operated by third parties and are not within AIR's control.              |  | Data collected at field locations is transferred to in-scope AIR systems using approved secure transfer methods as soon as practicable. Field researchers are briefed on data handling requirements via the travel security briefing process. |
| <b>Third-Party Supplier Infrastructure</b>          | Systems operated by AIR's suppliers and sub-processors on their own infrastructure (e.g. Atlassian cloud infrastructure, Microsoft hyperscale data centres) are not within AIR's administrative control. AIR is a tenant (not an operator).                           |  | AIR relies on contractual obligations, supplier security assessments, and published certifications to manage this boundary. Supplier security is addressed in RSK-008 and the Supplier Security Policy (AIR-ISMS-POL-005).                    |
| <b>External Partners Receiving Outputs Only</b>     | Partners who receive AIR research outputs (e.g. published reports, anonymised datasets) but who do not access AIR systems are outside scope. Once an output is delivered, AIR cannot control how the recipient handles it.                                            |  | Output classification and handling instructions are documented in delivery agreements. Outputs classified Restricted or Confidential are delivered via secure channels only.                                                                  |
| <b>Personally Owned Mobile Phones used for MFA</b>  | Staff use personal smartphones to run the Microsoft Authenticator app for MFA. AIR does not enrol or manage these devices; only the Authenticator application data is relevant to ISMS controls.                                                                      |  | MFA token data in the Authenticator app is managed by Microsoft Entra ID. AIR's Conditional Access policies govern the MFA requirement. No AIR business data is stored on personal phones.                                                    |

## 6. Interfaces with Out-of-Scope Entities

**Classification: Internal**

Where in-scope AIR systems or personnel interact with out-of-scope systems or parties, the interface must be controlled to prevent in-scope assets from being exposed to unmanaged risk. The following interfaces are documented and controlled.

| Interface                                                            | Direction                                                                 | Control Measures                                                                                                                                                                         |
|----------------------------------------------------------------------|---------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AIR staff → Government partner portals and data submission platforms | Outbound (AIR uploads data or retrieves data from client systems)         | Access from managed endpoints only. Data classified before transfer. Transfer method defined in data sharing agreement. Data retrieved is immediately brought into scope on AIR systems. |
| Government partner → AIR Azure Blob Storage (data delivery)          | Inbound (partner uploads research data to AIR-managed containers)         | Dedicated restricted-access storage containers. SAS token access with limited expiry. Azure Monitor logs all access. IT Operations reviews access on delivery.                           |
| ARIA API → Infrastructure operator systems                           | Outbound (operator queries AIR inference endpoints)                       | API access via authenticated HTTPS endpoints only. TLS 1.2 minimum enforced. API keys managed in Azure Key Vault. No model weights or training data transmitted, inference outputs only. |
| AIR staff → Atlassian Cloud (Jira / Confluence)                      | Outbound (staff access SaaS platforms hosted on Atlassian infrastructure) | Entra ID SSO enforced. MFA required. Restricted data must not be stored in Jira or Confluence, Internal classification is the maximum for these platforms.                               |
| Suppliers → AIR systems (data processing access)                     | Inbound (approved suppliers access AIR systems for service delivery)      | Scoped Entra ID accounts. Least-privilege access. Subject to supplier security assessment (RSK-008). Governed by Data Processing Agreement.                                              |
| Remote workers → AIR systems (via internet)                          | Bidirectional (staff access cloud systems over home/public networks)      | MFA enforced. Managed device required. VPN required for on-premises Madrid HQ access. Conditional Access enforces compliance posture check before session.                               |

## 7. Applicability to Annex A Controls

All 93 ISO/IEC 27001:2022 Annex A controls have been assessed for applicability against this scope. The assessment is documented in the Statement of Applicability (AIR-ISMS-SOA-001). No controls have been excluded based on scope. All 93 controls are applicable given the breadth of AIR's operational environment and the sensitivity of the information assets it holds.

The scope inclusions most material to individual control themes are:

| Annex A Theme               | Scope Elements Most Relevant                                                                                                                                                                                                                 |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 5 — Organisational Controls | All departments, all personnel, all business activities, and all information assets in the Asset Inventory. Supplier relationships and government partner obligations are particularly significant.                                          |
| 6 — People Controls         | All 120 permanent employees and 25 contractors. Onboarding, training, disciplinary, and offboarding processes across all three locations.                                                                                                    |
| 7 — Physical Controls       | Madrid HQ (server room, physical access, CCTV, UPS). Brussels and Riga offices (physical access, clean desk). Remote working endpoints.                                                                                                      |
| 8 — Technological Controls  | All in-scope systems (Azure, M365, GitHub, Intune, on-premises repositories). Particular relevance of authentication (8.5), logging (8.15), monitoring (8.16), endpoint devices (8.1), and privileged access (8.2) given AIR's risk profile. |

## 8. Scope Change Management



**Classification: Internal**

The ISMS scope must be updated when material changes occur that affect the boundary. The following triggers require a formal scope review:

- Addition of a new office location or significant change to an existing location
- Adoption of a new system or platform that processes Restricted or Confidential information
- Decommissioning of a system currently within scope
- Significant change to the workforce composition (e.g. a major contractor programme or expansion into a new country)
- A new government research contract that introduces data handling obligations not currently covered by the ISMS
- Any change to AIR's legal structure, ownership, or regulatory jurisdiction
- An audit finding or incident that reveals a material gap in scope coverage

Scope changes must be approved by the Head of Security & Compliance and the Chief Executive Officer before taking effect. Where a scope change is material (i.e. it adds or removes a significant system, location, or population), the risk register and Statement of Applicability must be reviewed and updated within 30 days of the scope change approval.

| Step | Action                                                                                                                        | Owner                           |
|------|-------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| 1    | Identify trigger event or proposed change.                                                                                    | Any AIR staff member or manager |
| 2    | Head of Security & Compliance conducts impact assessment: does the change affect scope, risk profile, or applicable controls? | Head of Security & Compliance   |
| 3    | If scope impact confirmed: update this document (AIR-ISMS-SCO-001) and submit for approval.                                   | Head of Security & Compliance   |
| 4    | CEO approval of updated scope.                                                                                                | Chief Executive Officer         |
| 5    | Update Risk Register (AIR-ISMS-RSK-002) and SoA (AIR-ISMS-SOA-001) to reflect scope change within 30 days.                    | Head of Security & Compliance   |
| 6    | Communicate scope change to all affected personnel and departments.                                                           | Head of Security & Compliance   |

## 9. ISMS Document Hierarchy

This document sits at the foundation of AIR's ISMS document hierarchy. The full set of ISMS documents and their relationship to this scope statement is:

| Document ID      | Title                                | Relationship to Scope                                                             |
|------------------|--------------------------------------|-----------------------------------------------------------------------------------|
| AIR-ISMS-ORG-001 | Organisation Profile                 | Provides the Clause 4.1 and 4.2 inputs that determined this scope. Read first.    |
| AIR-ISMS-SCO-001 | ISMS Scope Statement (this document) | Defines the boundary of the ISMS. All other documents apply within this boundary. |
| AIR-ISMS-AST-001 | Information Asset Inventory          | Lists all information assets within scope. Must be consistent with Section 4.4.   |
| AIR-ISMS-RSK-001 | Risk Assessment Methodology          | Applies to all assets and threats within the defined scope.                       |
| AIR-ISMS-RSK-002 | Risk Register                        | Documents risks to assets within scope. Out-of-scope items are not risk-assessed. |
| AIR-ISMS-POL-001 | Information Security Policy          | Applies to all personnel and activities within scope.                             |
| AIR-ISMS-POL-002 | Access Control Policy                | Governs access to all in-scope systems and assets.                                |
| AIR-ISMS-POL-003 | Incident Response Policy             | Covers incidents affecting in-scope systems and assets.                           |
| AIR-ISMS-SOA-001 | Statement of Applicability           | Assesses all 93 Annex A controls against this defined scope.                      |

**Classification: Internal**

|                  |                              |                                                           |
|------------------|------------------------------|-----------------------------------------------------------|
| AIR-ISMS-AUD-001 | Internal Audit Report        | Audits ISMS implementation within this defined scope.     |
| AIR-ISMS-RMP-001 | Security Improvement Roadmap | Plans improvements to controls within this defined scope. |

## 11. Approval

---

| Role               | Name                          | Signature | Date     |
|--------------------|-------------------------------|-----------|----------|
| Document Owner     | Head of Security & Compliance |           | May 2026 |
| Executive Approver | Chief Executive Officer       |           | May 2026 |